

Pentesting - Offensive: Red Team, Pentester & Researcher

Taller de Seguridad
Ing. Martin Di Paola - Fiuba

Threat Model well thought.
Mechanisms and policies are
in-place, in each sec interface.

Now...

- Are **correctly** configured?
- Did I **forget** something?
- On an attack, would I **block** it?
 - Would I **notice** it?
 - Would I know how to react?

All the defences are
perfect until they are
tested for real.

Penetration test
(aka pentest)

Red Team

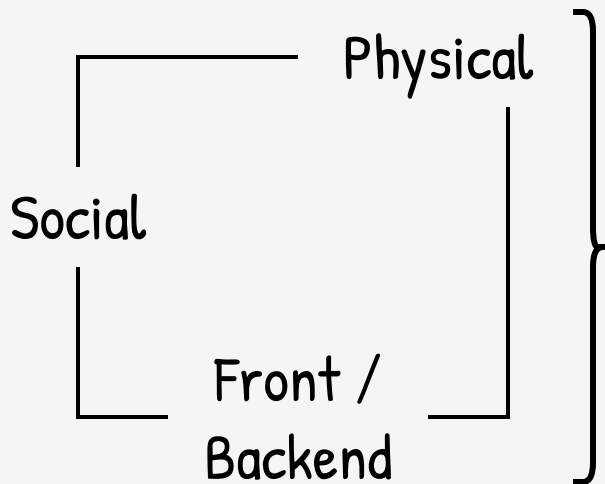
Pentester

Researcher

Red Team

Pentester

Researcher



Multi-disciplines

A chain is only as strong as its weakest link

Goal
Simulate real attacks

Red Team

Physical
Social
Front /
Backend

Multi-
disciplines

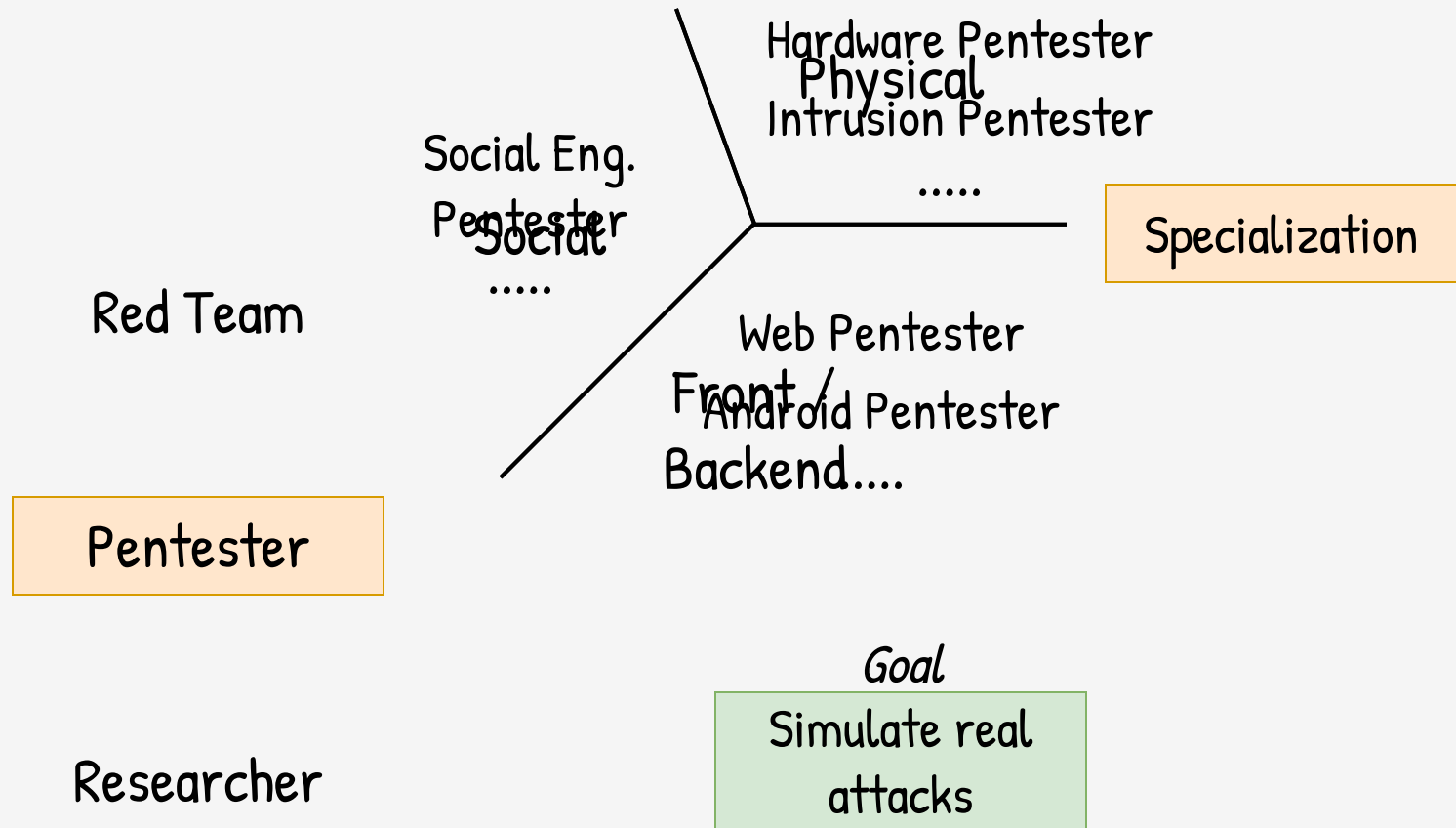
Pentester

A chain is only as
strong as its
weakest link

Researcher

HIS LAPTOP'S ENCRYPTED.
DRUG HIM AND HIT HIM WITH
THIS \$5 WRENCH UNTIL
HE TELLS US THE PASSWORD.





Red Team

Exploit Writting 

Windows Kernel

Android Kernel

Xen Hypervisor

Pentester

Reversing Eng. 

BIOS

Hardware

Cryptography 

Signing Scheme

Chain Analysis

Researcher

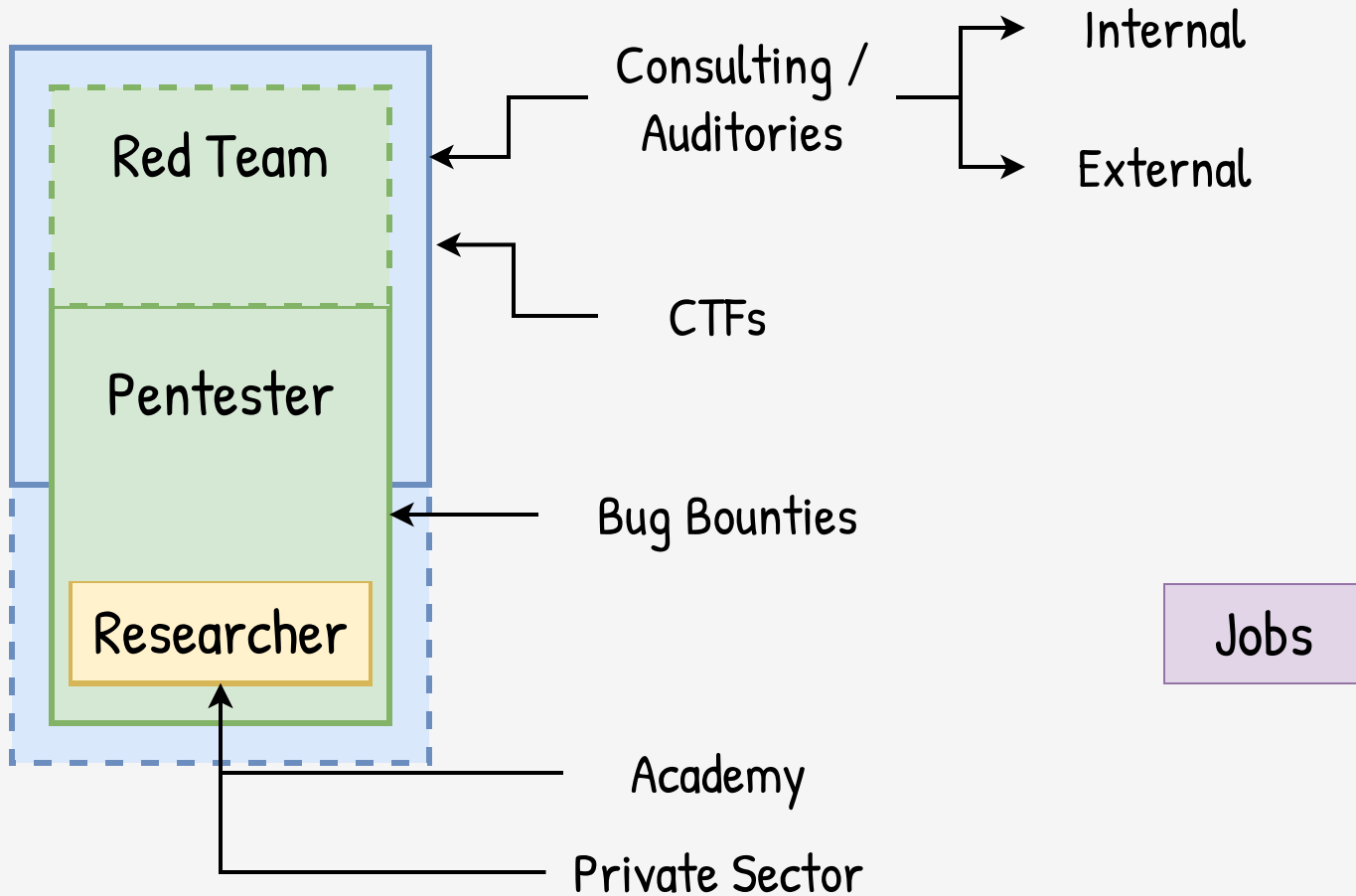
Malware Analysis 

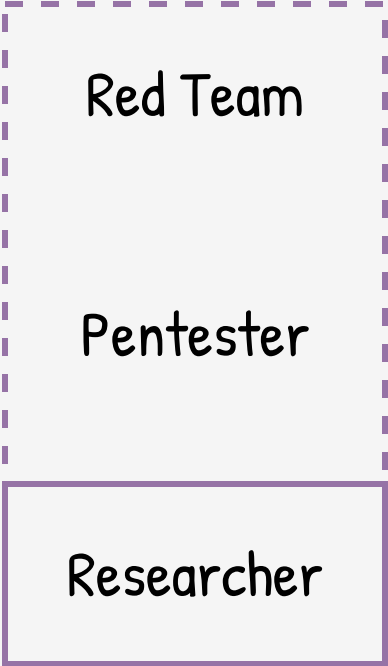
Antivirus Detection

Sandbox

Goal

Develop *new* vulns
& techniques





Red Team

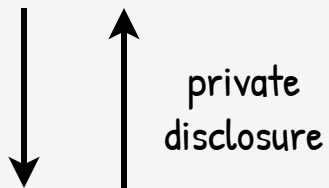
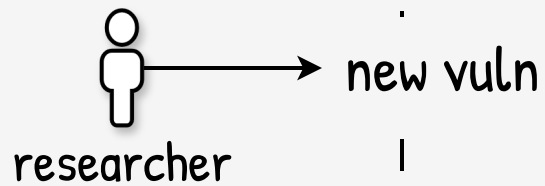
Pentester

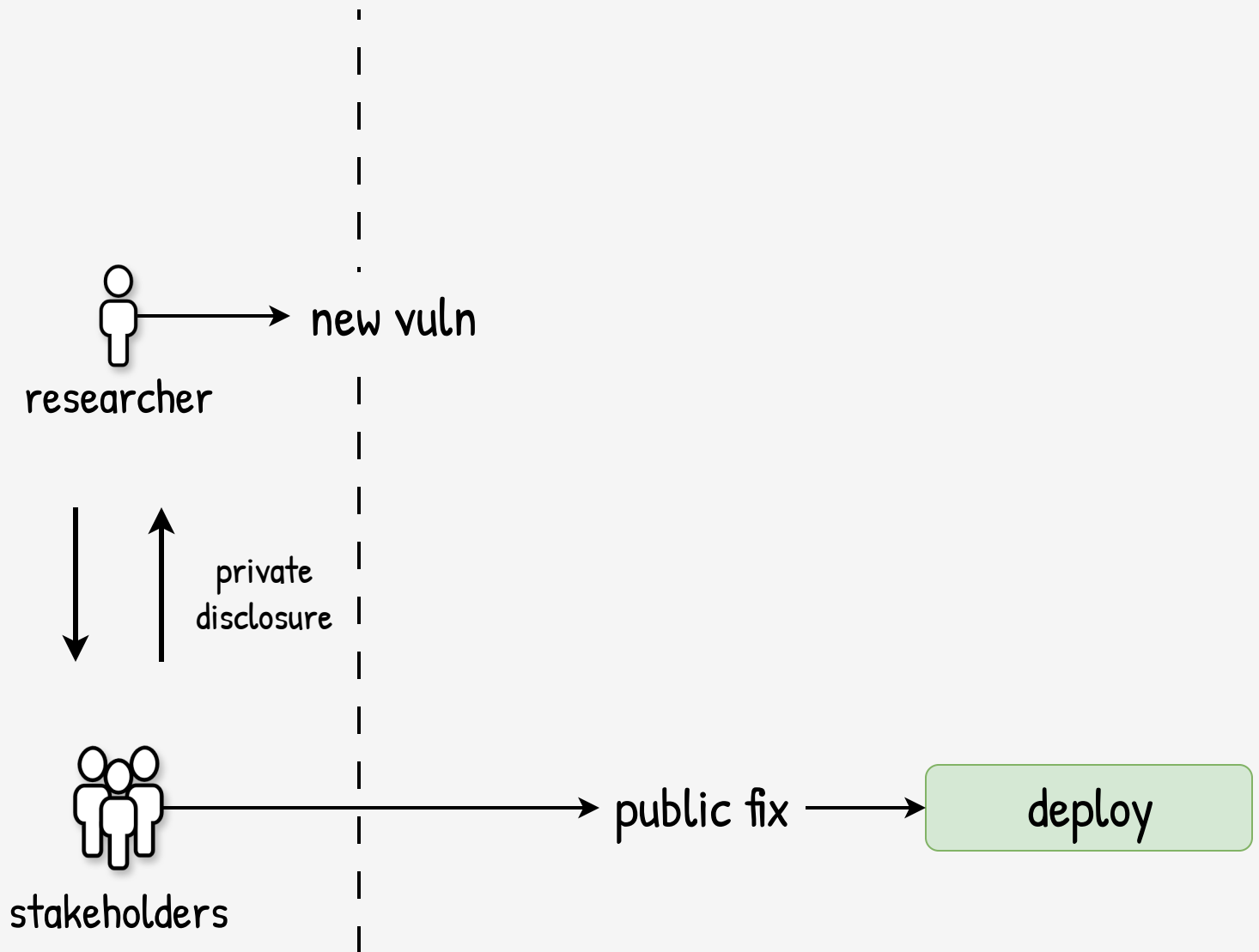
Researcher

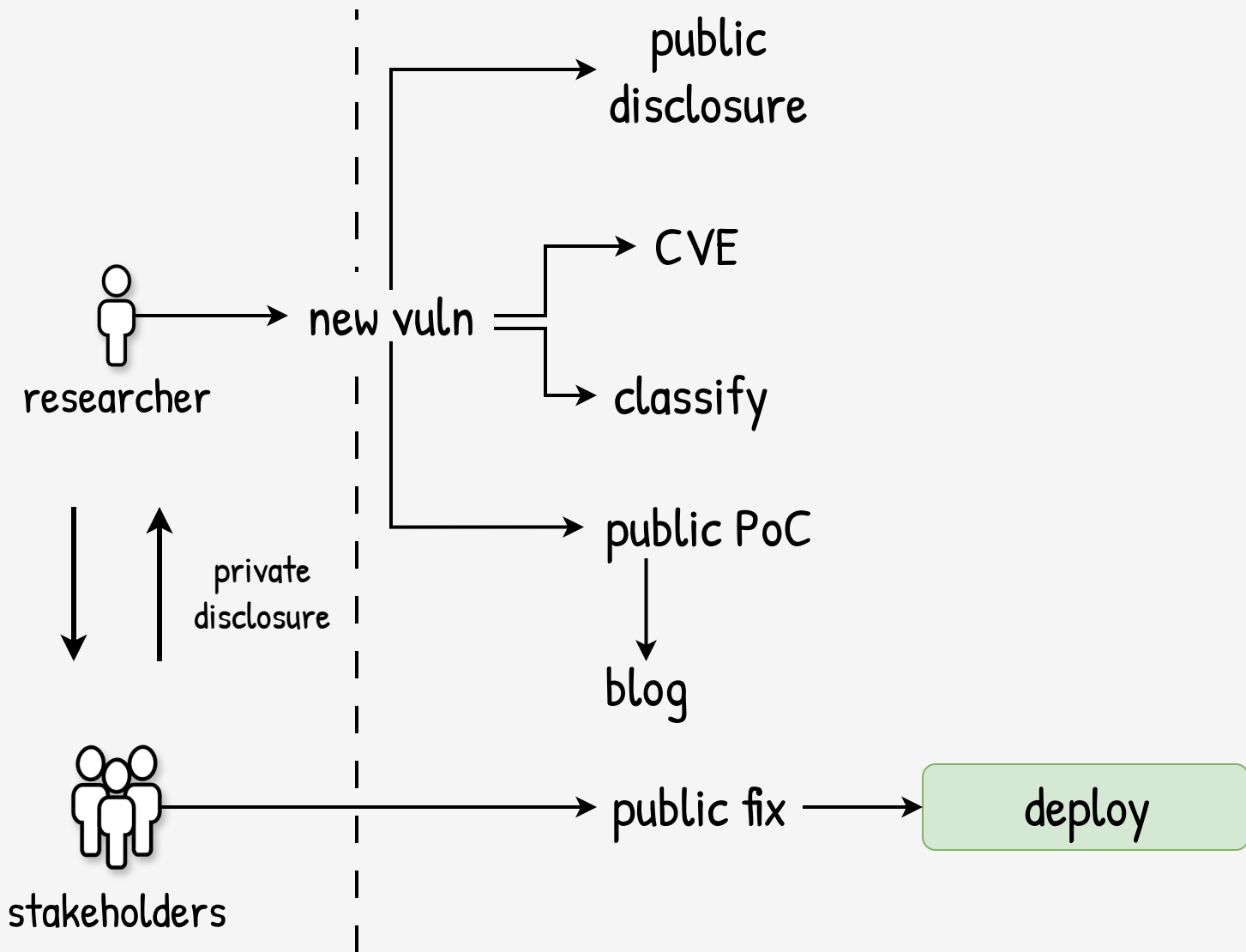
Disclosure

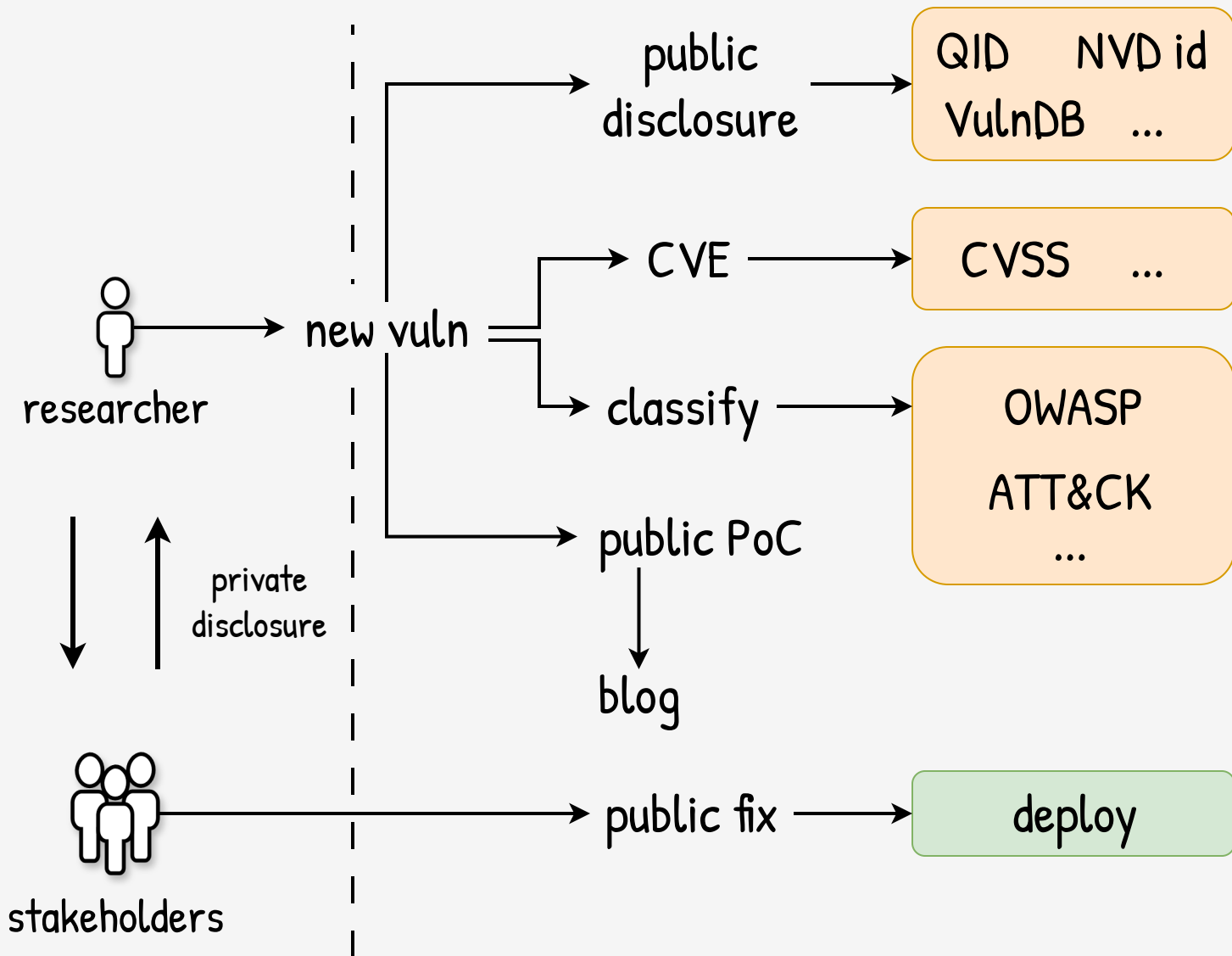
(but **check** with legals)

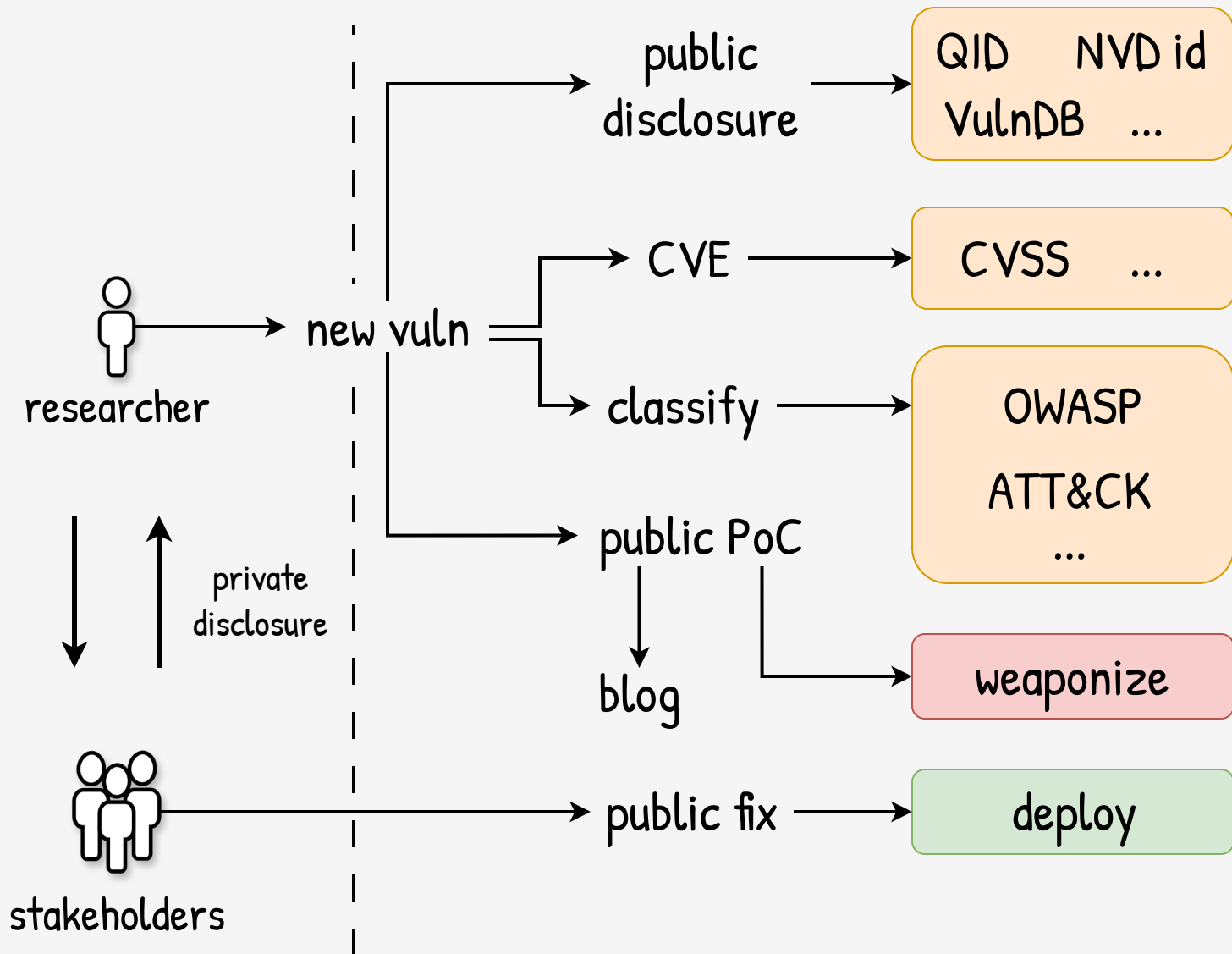
- Share findings
- Coordinate schedule for fix, revalidation and disclosure
- 90 days deadline for full disclosure
- It shouldn't be necessary but sometimes you need to *"hide"* yourself

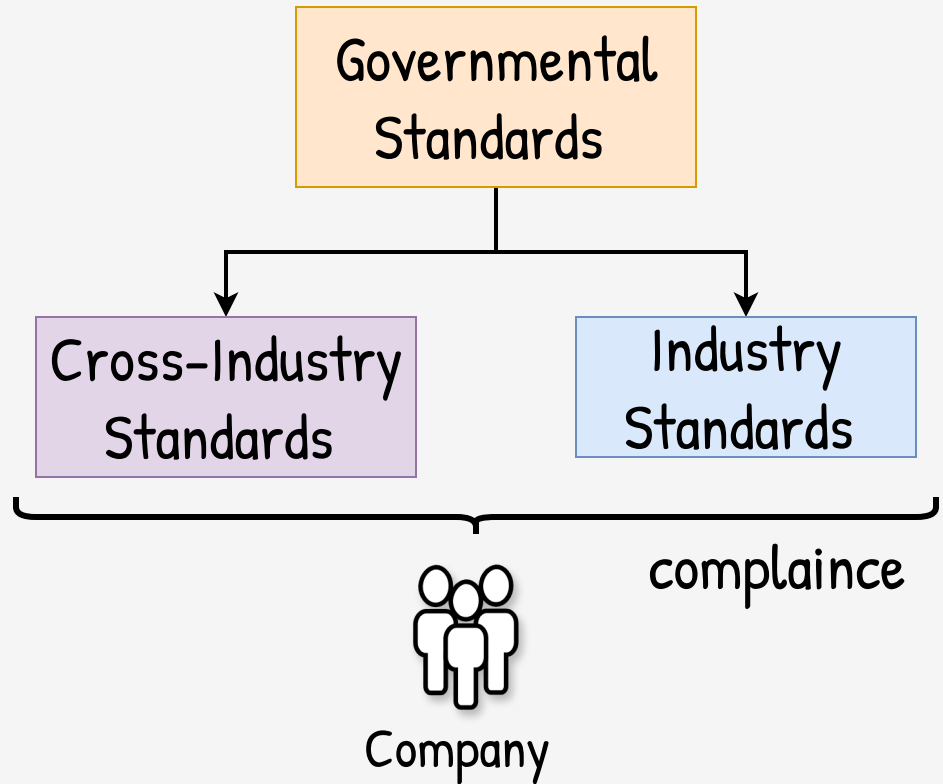
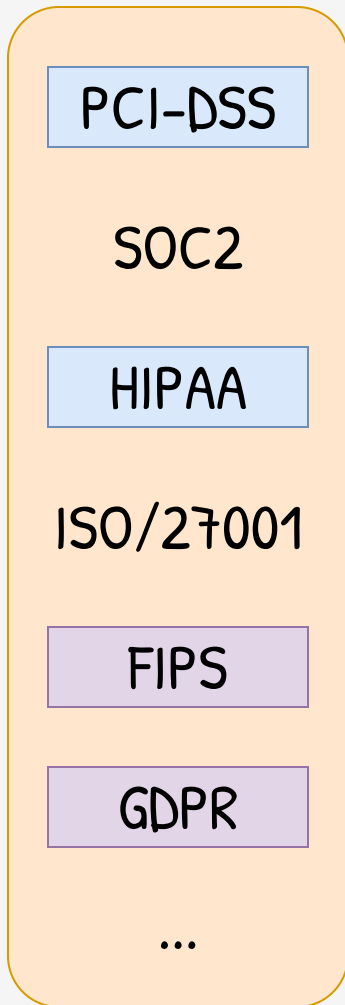


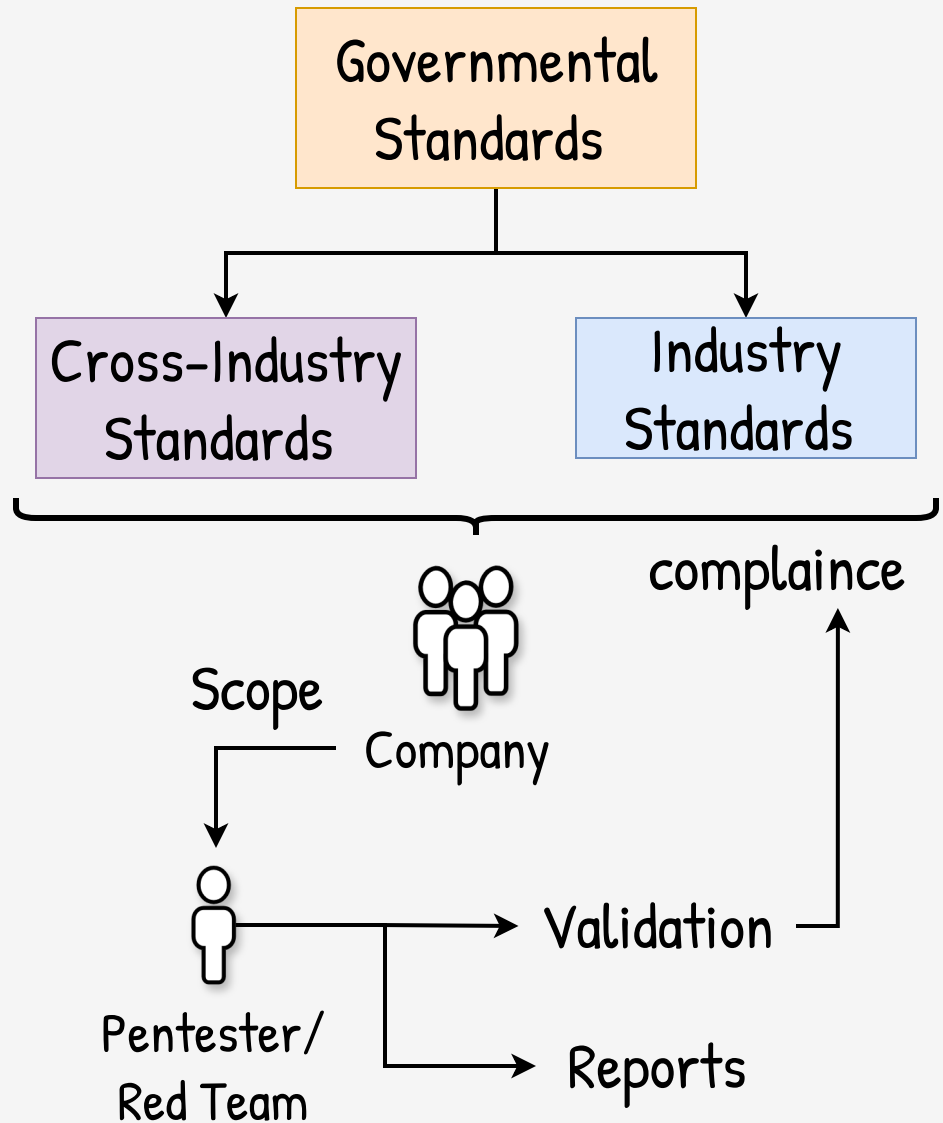
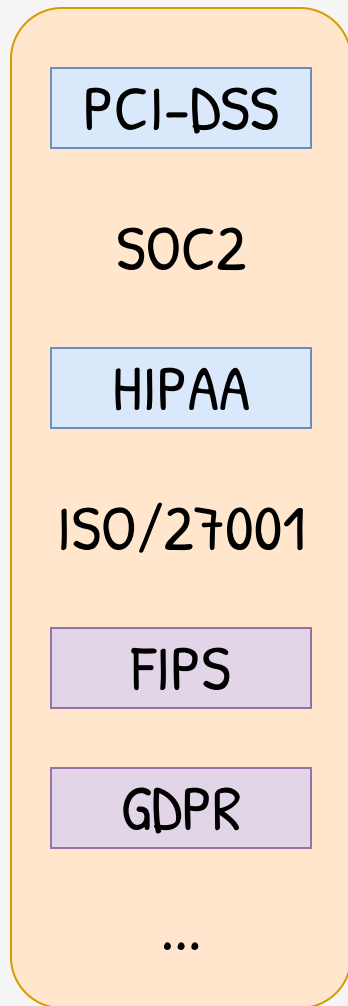












- What should we focus on?
- What is and isn't allowed?
- What initial info do we have?
- What is the timeframe? Any schedule restriction?
- What is the legal framework?

Scope



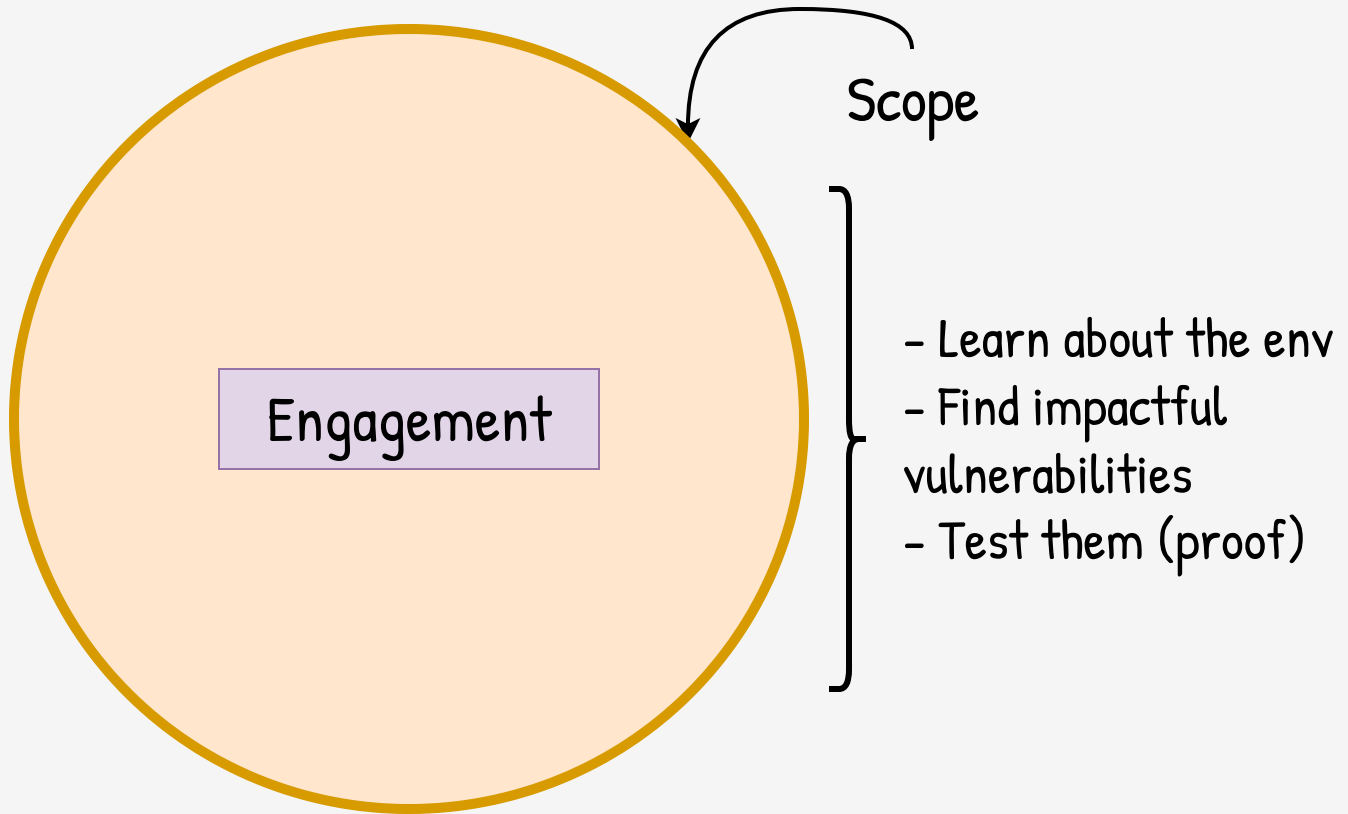
Client

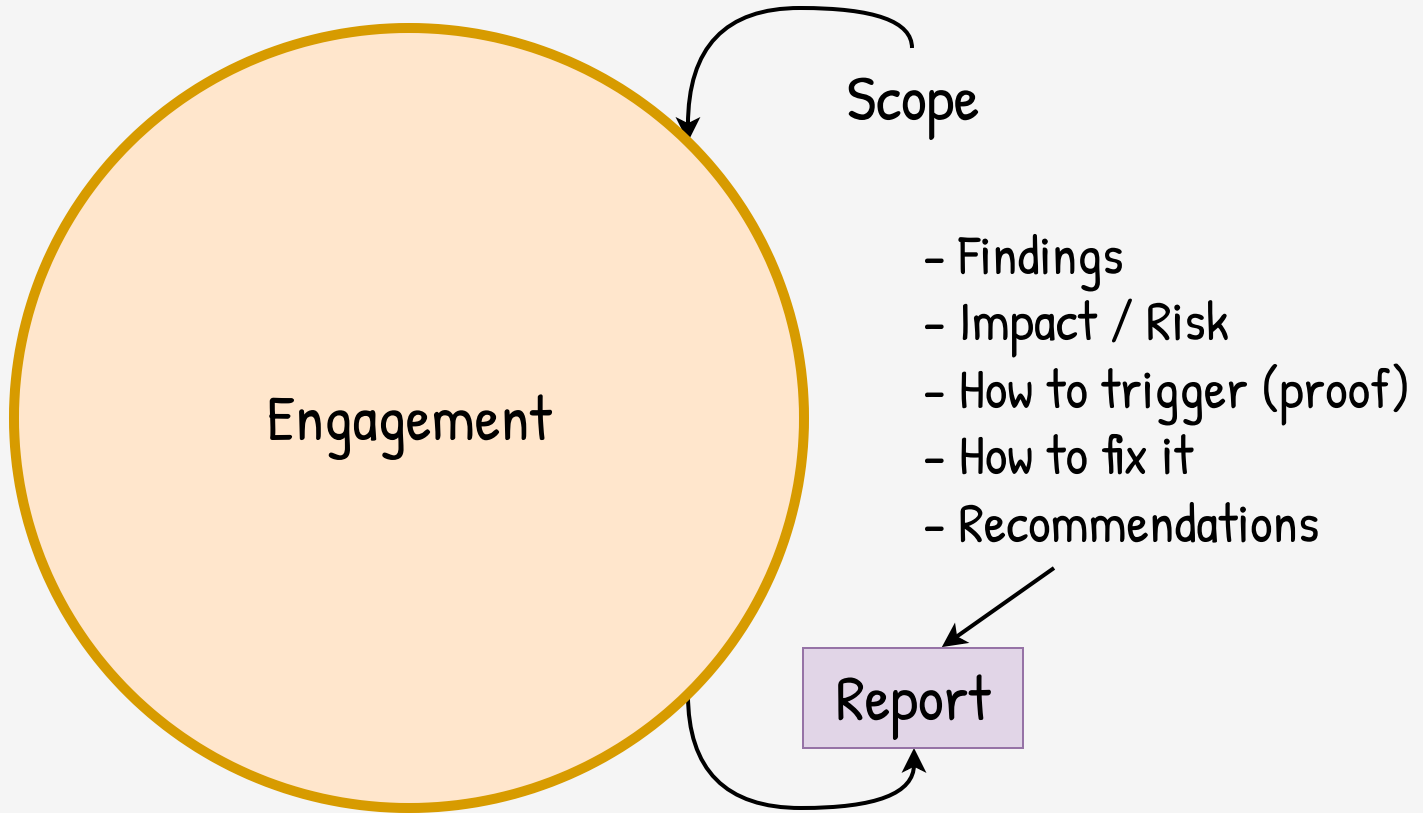


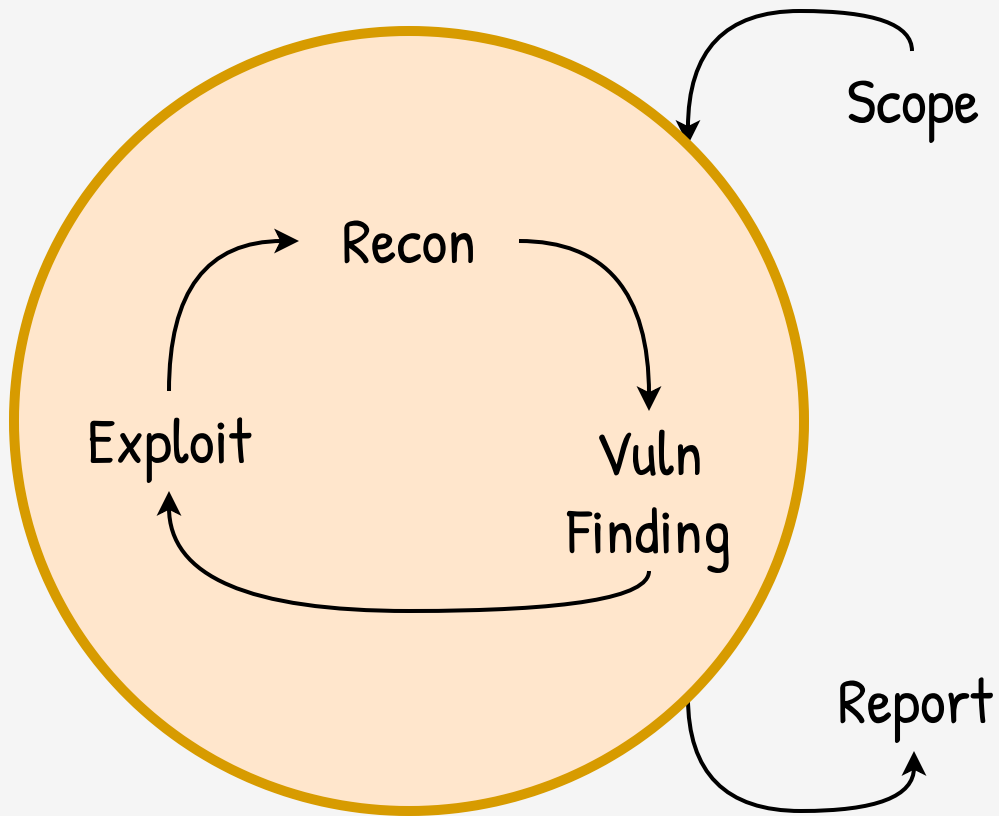
Written
Contract

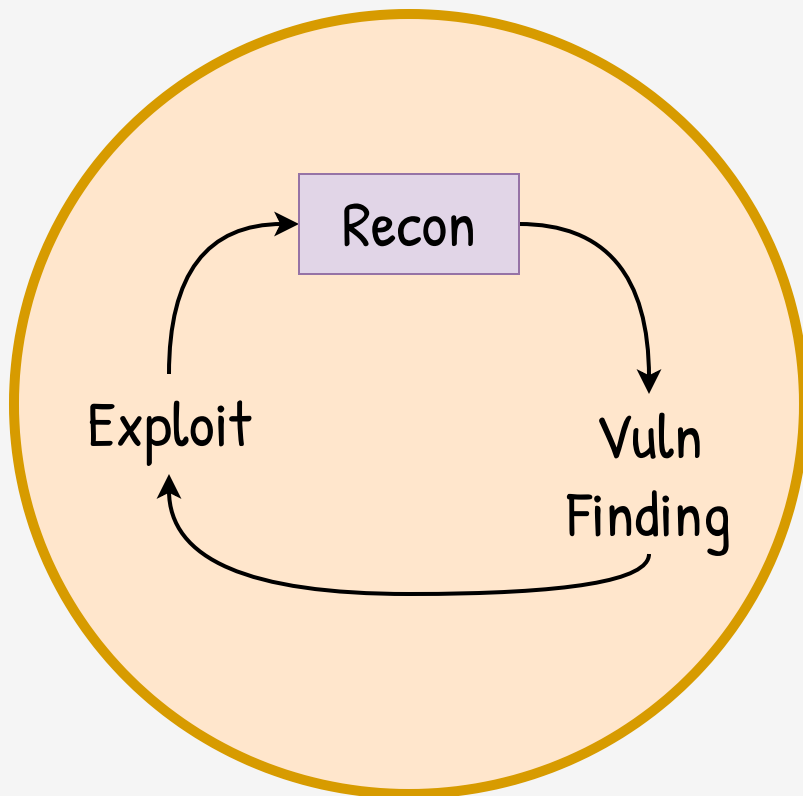


Red Team /
Pentester



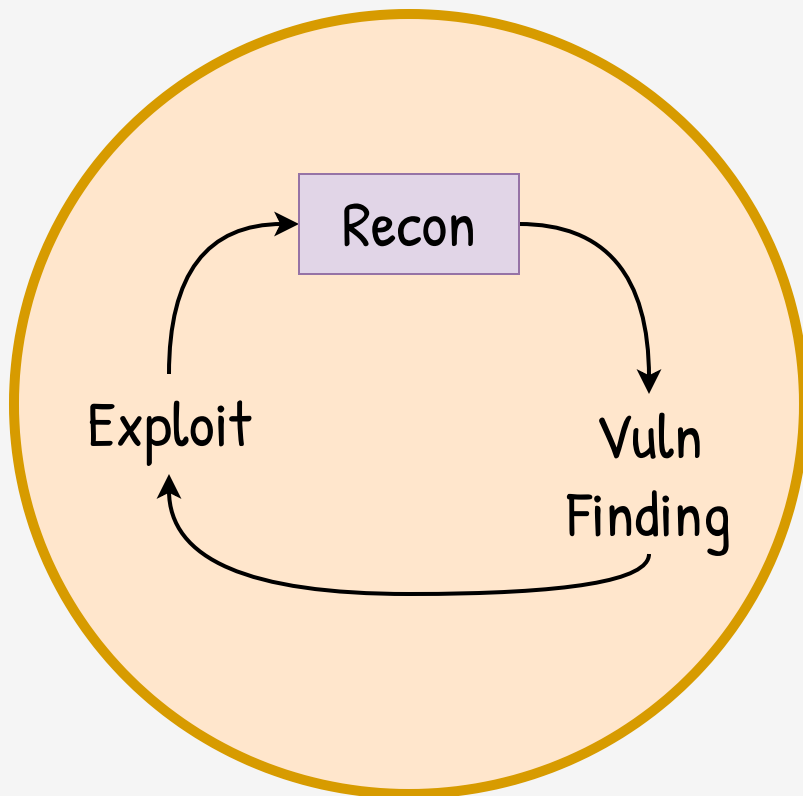






Reconnaissance / Information Gathering

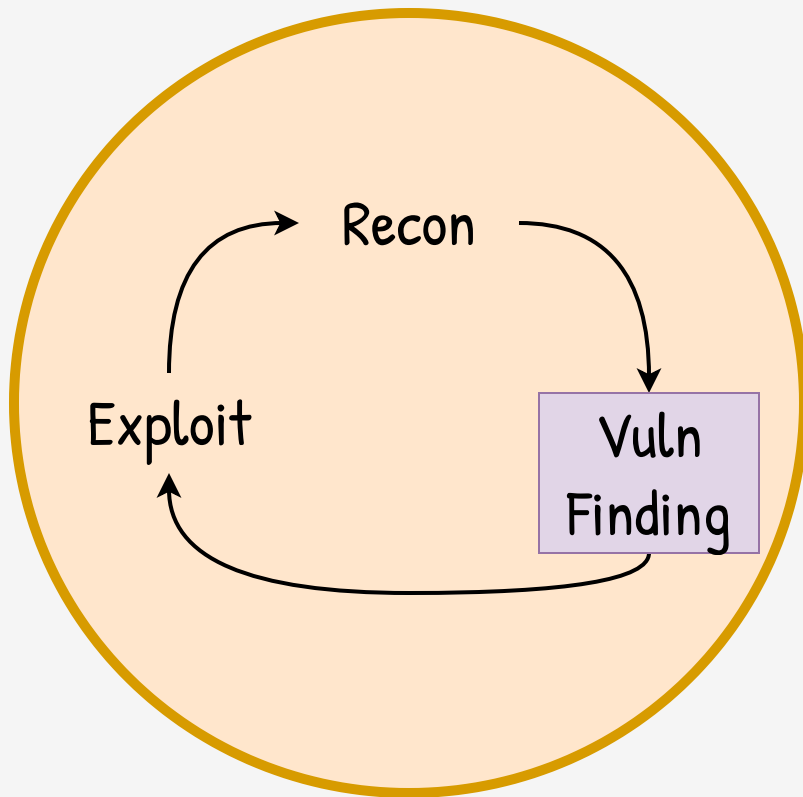
- Hosts, ports, fw rules, DNS
- Processes, users, services, permissions, prog versions
- People names, emails, roles



Reconnaissance / Information Gathering

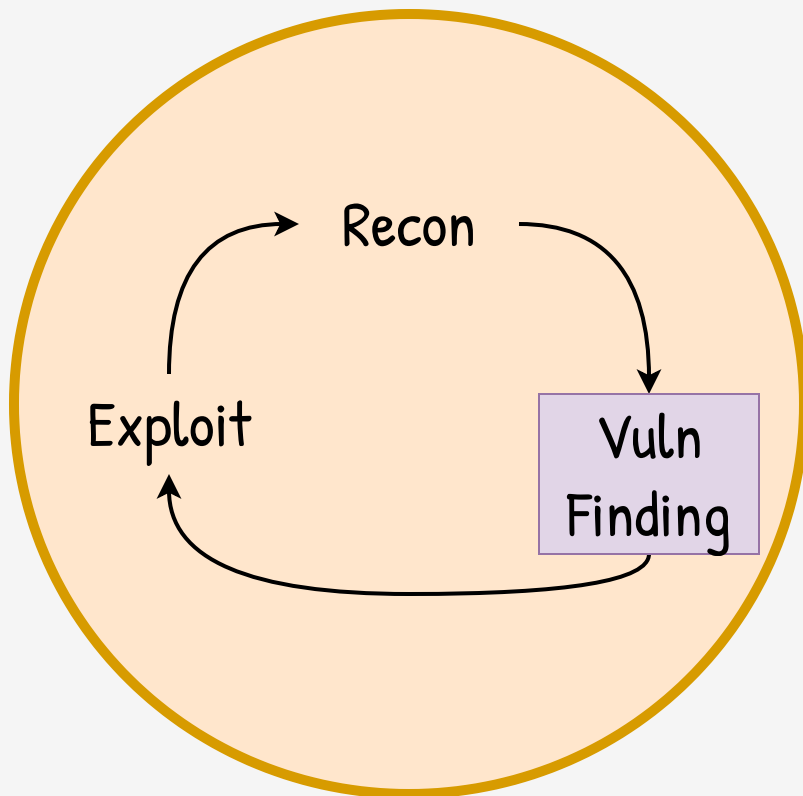
- Hosts, ports, fw rules, DNS
- Processes, users, services, permissions, prog versions
- People names, emails, roles

Learn, visibility and
plan the next step



Vulnerability Finding

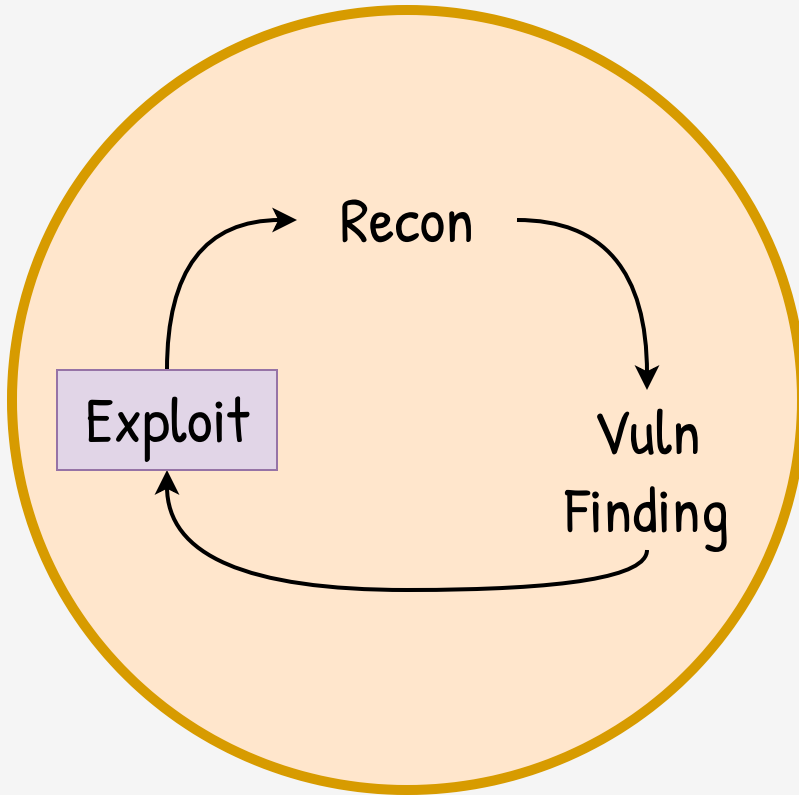
- What can we read/write/exec and we should't?
- Info leak, priv escalation, ...
- Proof of their existence



Vulnerability Finding

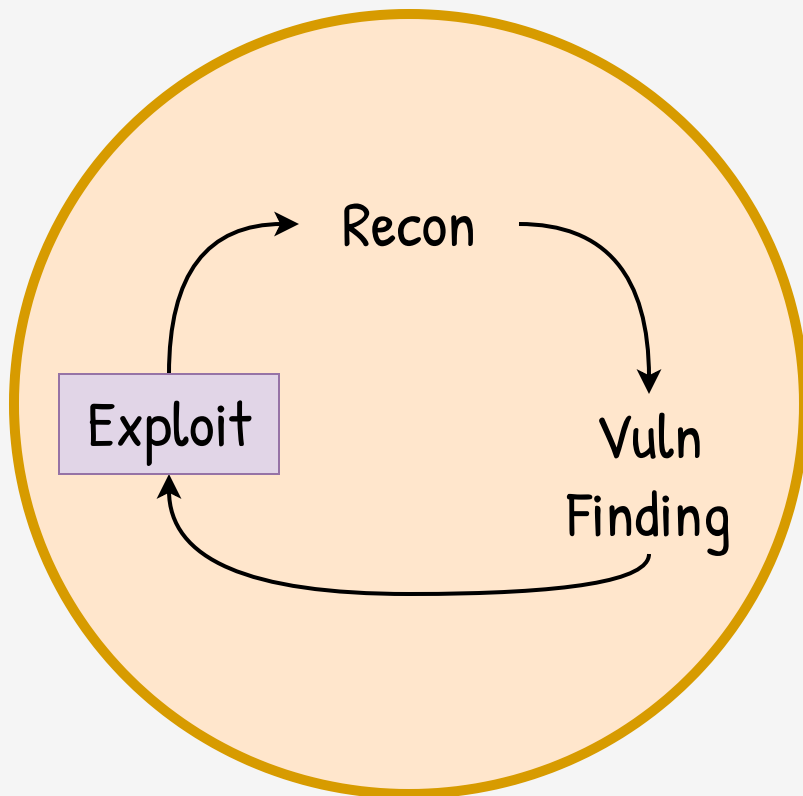
- What can we read/write/exec and we should't?
- Info leak, priv escalation, ...
- Proof of their existence

Find vulns relevant to our client and/or to our engagement



Exploit a Vulnerability

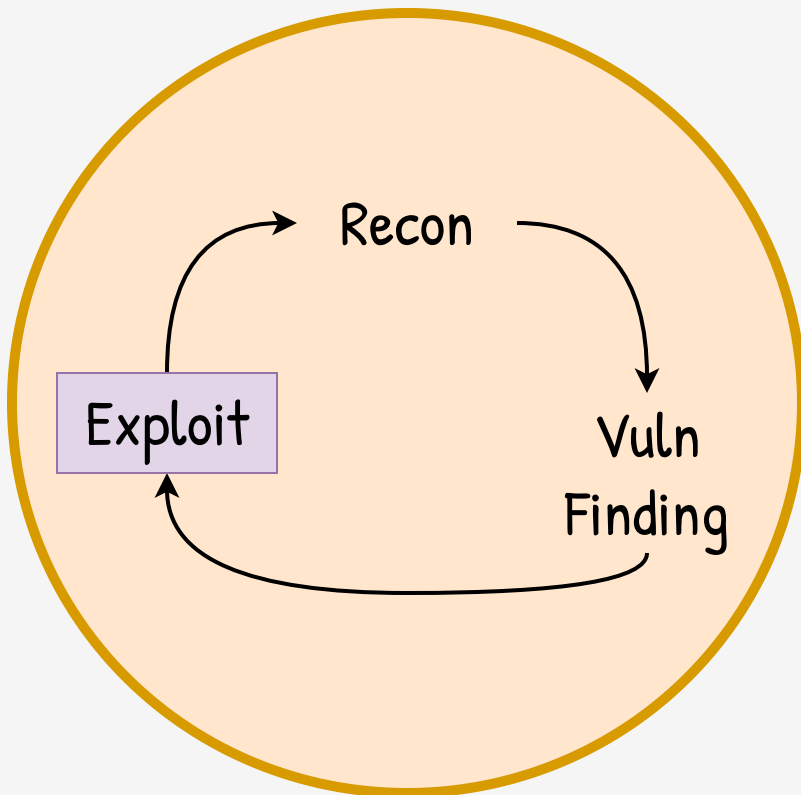
- Take advantage of a vuln to actually read/write/exec
- Do not cross scope or legal



Exploit a Vulnerability

- Take advantage of a vuln to actually read/write/exec
- Do not cross scope or legals

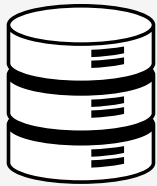
- Privilege escalation
- Lateral movement
- See further
- Get the cookie



Exploit a Vulnerability

- Take advantage of a vuln to actually read/write/exec
- Do not cross scope or legal

Enable **more** recon &
vuln finding



prod DB



pub.47



pub.48

Company's
internal network

Scope:

- scan is OK
 - IPs: pub.47 pub.48
- use creds OK
 - but no creds given
- social eng NOT ok
- use exploits on prod NOT ok
- no more info (blackbox)

Goal:

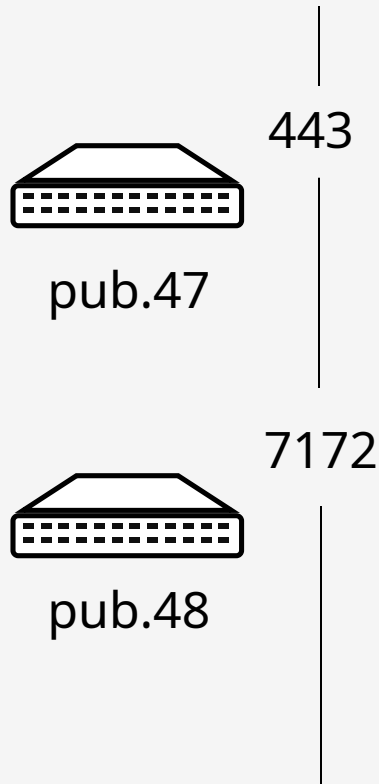
- ~~exfiltrate prod DB~~
 - that's NOT for legals (us),
 - better: **prove** that prod DB can be exfiltrated

What's next?

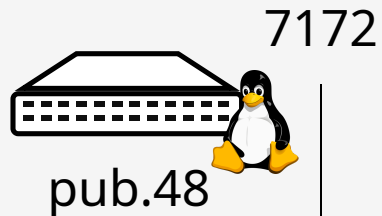
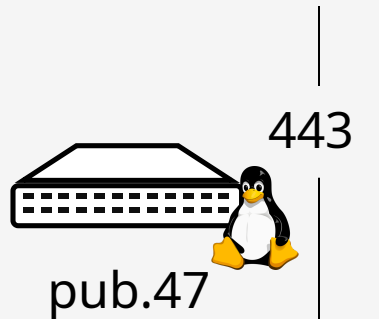
pub.47

pub.48

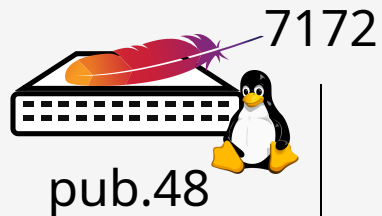
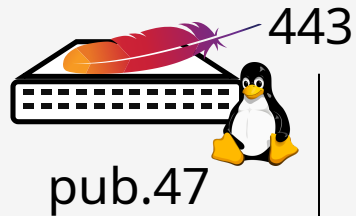
nmap pub.47
nmap pub.48



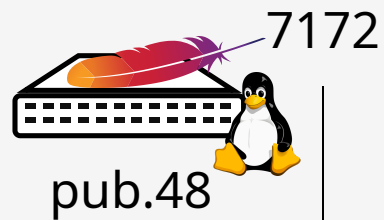
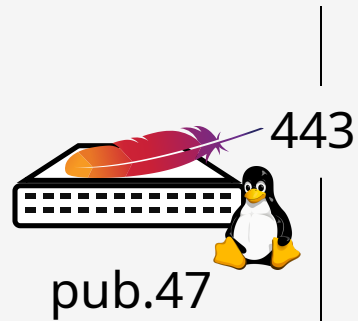
```
nmap pub.47  
nmap pub.48
```



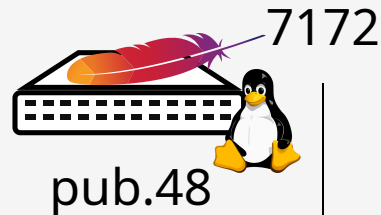
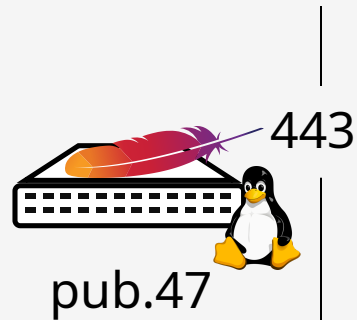
```
nmap pub.47  
nmap pub.48
```



What's next?



Recon



Email address

email@example.com

Password

Password

☐ Remember me

Sign in

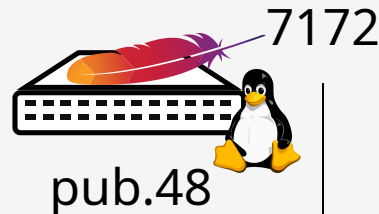
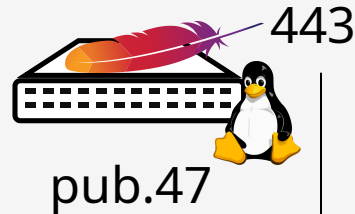
New around here? Sign up

Forgot password?

emails:

- from social networks
- from public websites
- from default lists

X



Email address

email@example.com

Password

Password

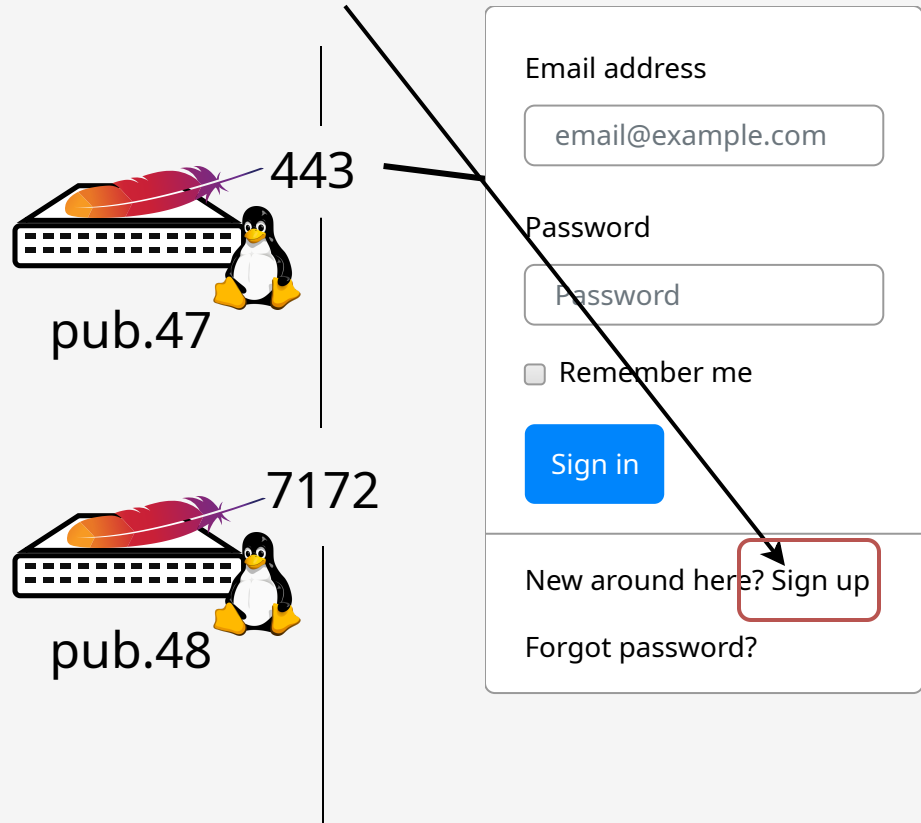
☐ Remember me

Sign in

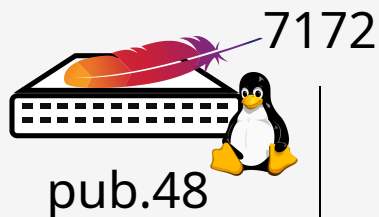
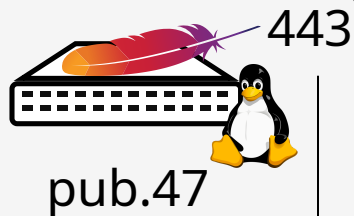
New around here? Sign up

Forgot password?

X create account?
- it asks for a registration
code that we don't have



X password recovery?
- it looks solid



Email address

email@example.com

Password

Password

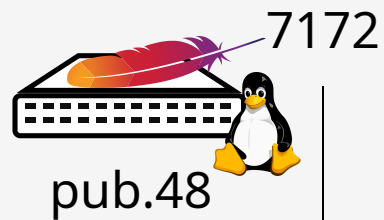
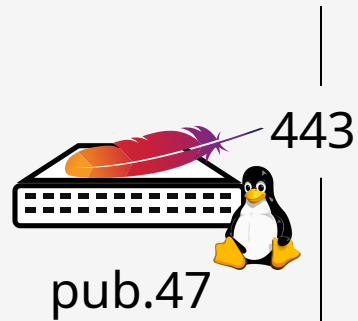
☐ Remember me

Sign in

New around here? Sign up

Forgot password?

What's next?

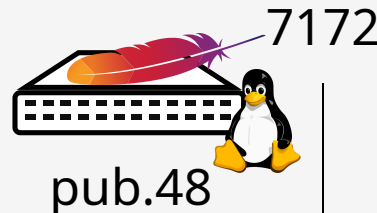
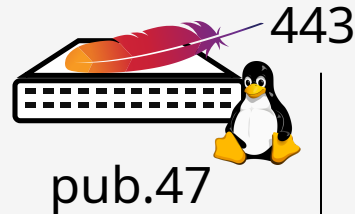


emails:

- from social networks
- from public websites
- from default lists



email: test@test.com
pass: testing



Email address

email@example.com

Password

Password

☐ Remember me

Sign in

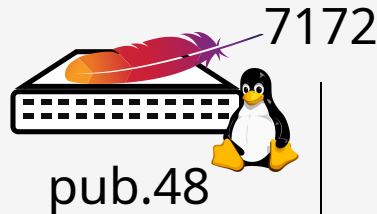
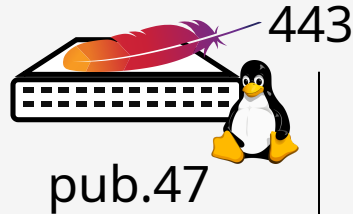
New around here? Sign up

Forgot password?

Find Vuln

? john' or 1=1
? john" or 1=1
✓ john' || pg_sleep(1) --

???



New message to @mdo

Recipient:

@mdo

Message:

Close

Save changes

?

john' or 1=1

?

john" or 1=1

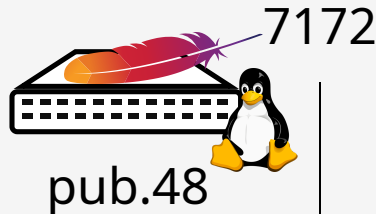
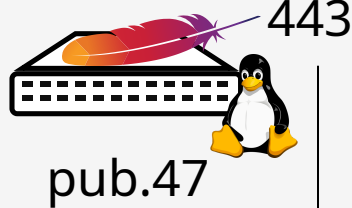


john' || pg_sleep(1) --

sqli

Find Vuln

(blind)



New message to @mdo

Recipient:

@mdo

Message:

Close

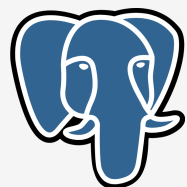
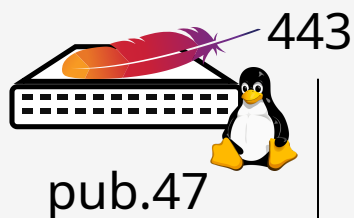
Save changes

SQL injections to
learn about the DB
and environment

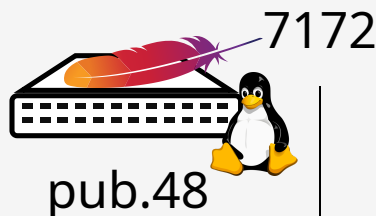
sqli

Recon

(blind)



postgres
ver 12.1
superuser



New message to @mdo

Recipient:

@mdo

Message:

Close

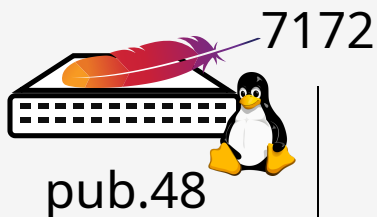
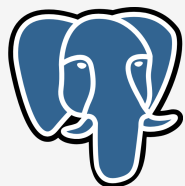
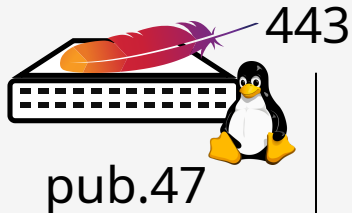
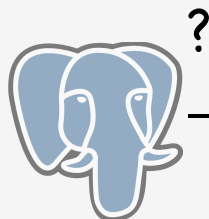
Save changes

SQL injections to
learn about the DB
and environment

sqli

Recon

(blind)



postgres
ver 12.1
superuser

New message to @mdo

Recipient:

@mdo

Message:

Close

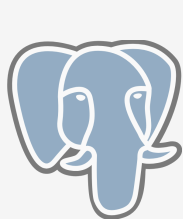
Save changes

SQL injections to
learn about the DB
and environment

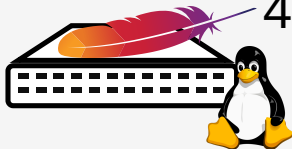
sqli

What's next?

(blind)



?



443

pub.47



postgres
ver 12.1
superuser



7172

pub.48

New message to @mdo

Recipient:

@mdo

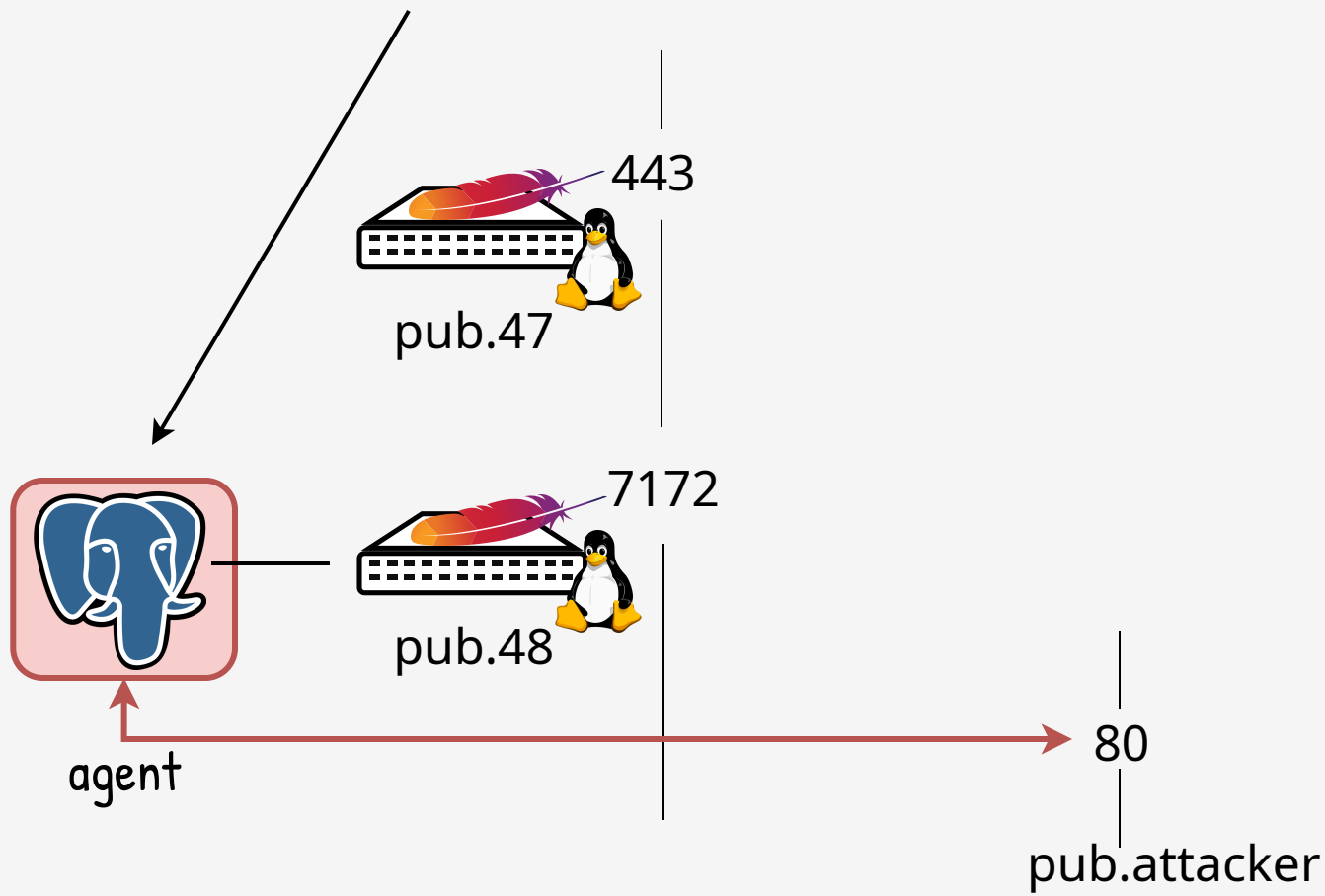
Message:

Close

Save changes

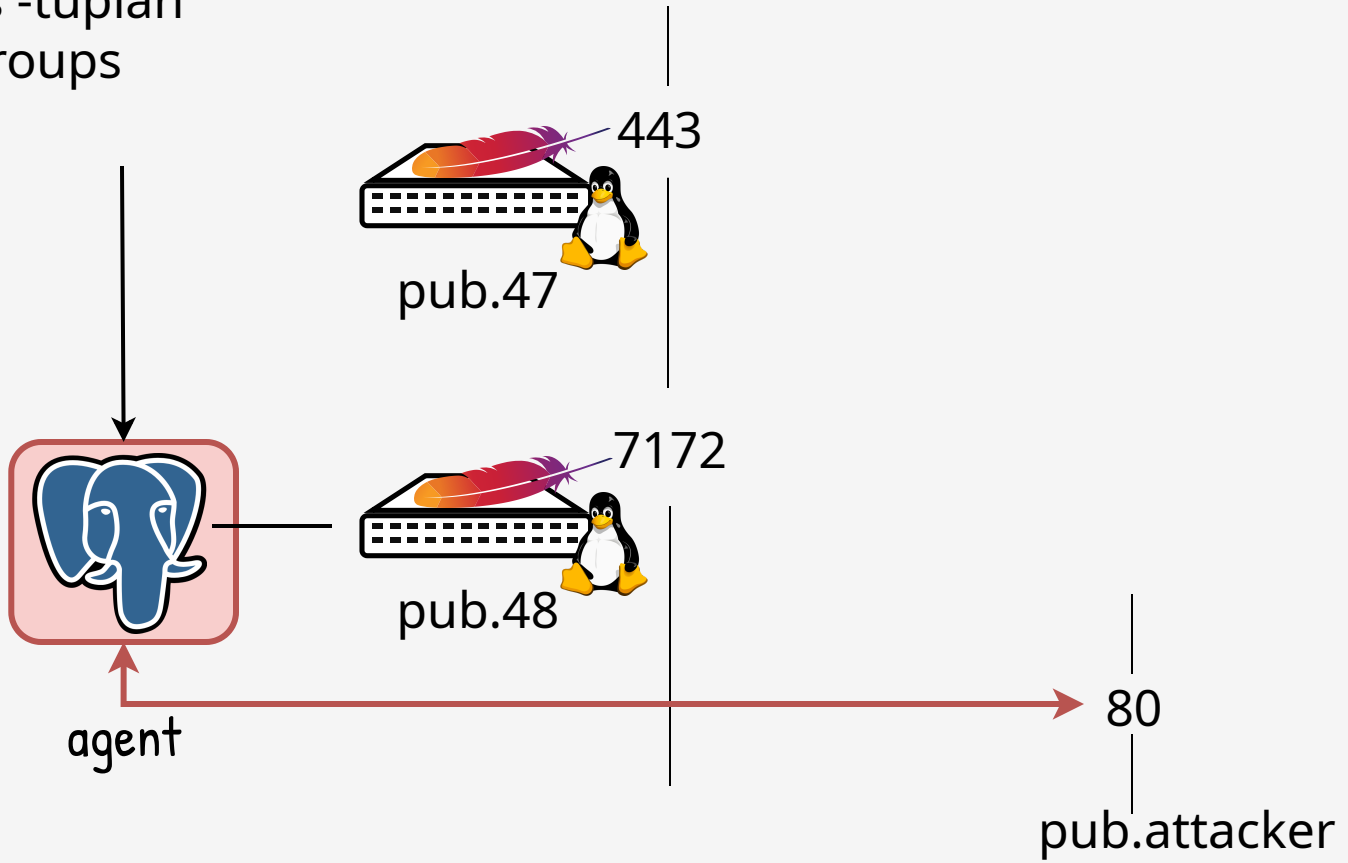
Exploit

```
COPY (SELECT '')  
TO PROGRAM '...shellcode...';
```

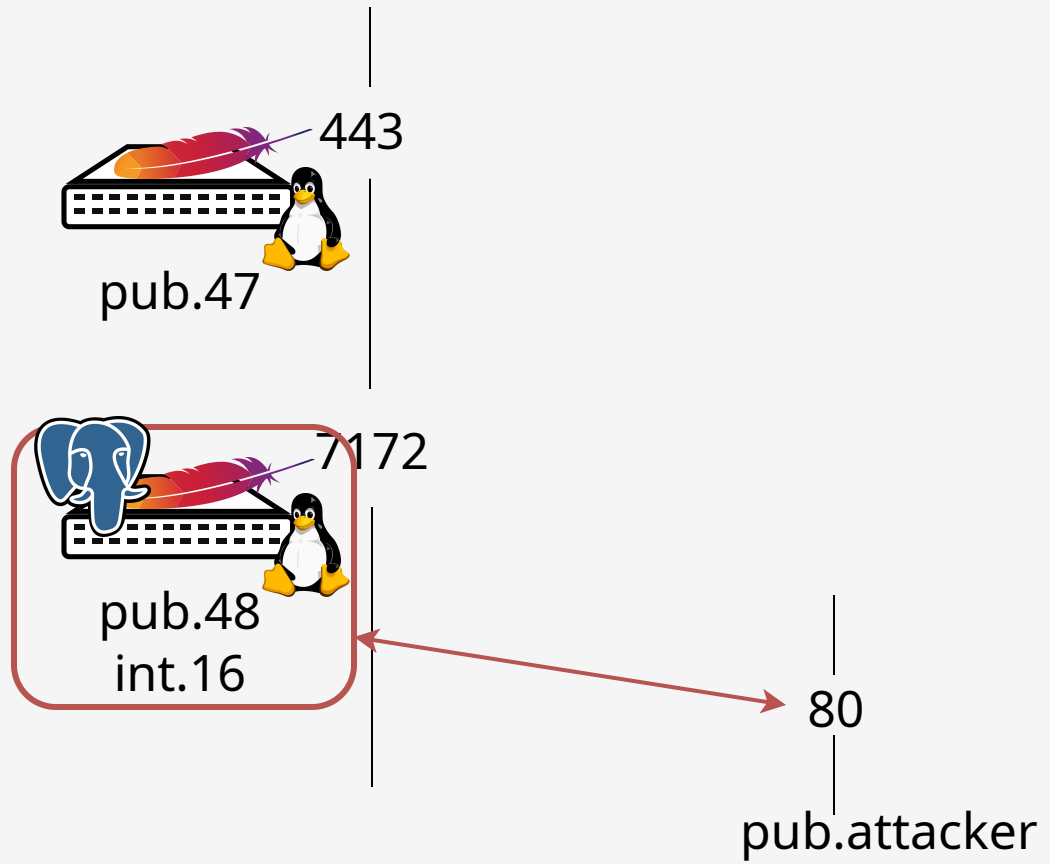


Recon

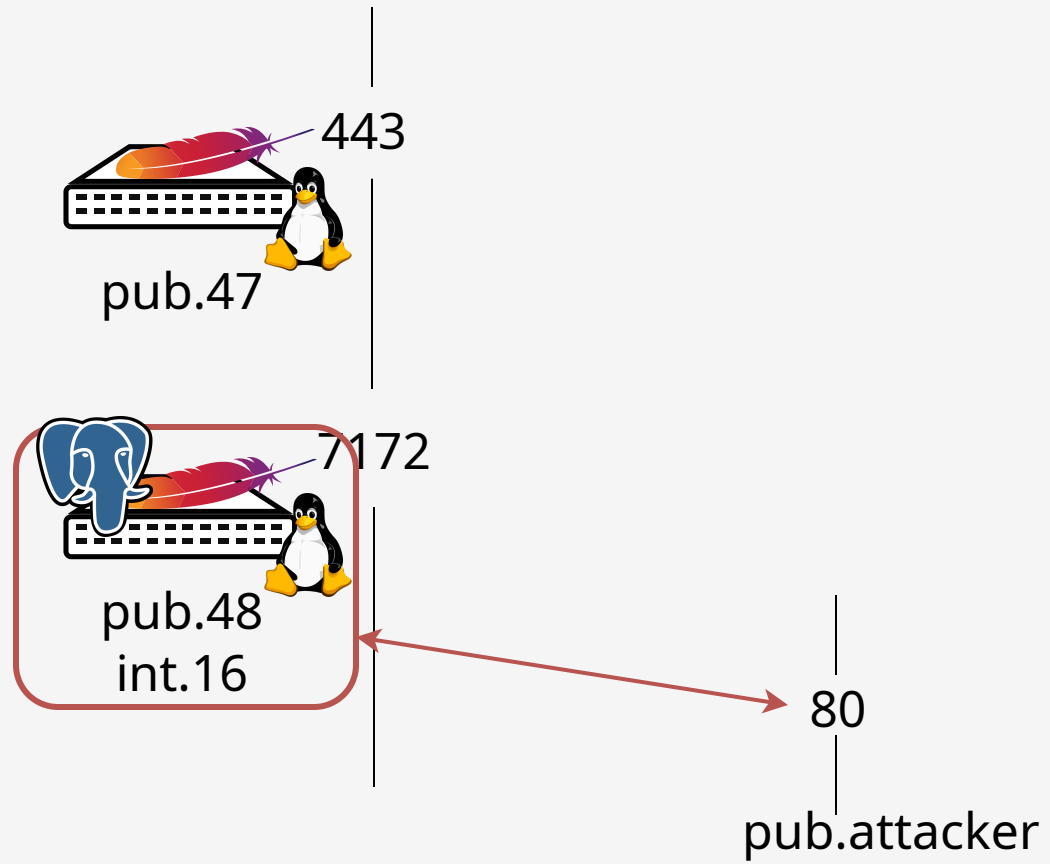
ps aux
ip addr
ss -tuplan
groups
...



Recon



What's next?



Recon



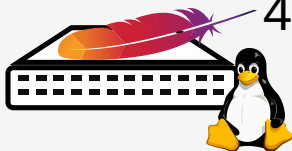
int.18



int.17

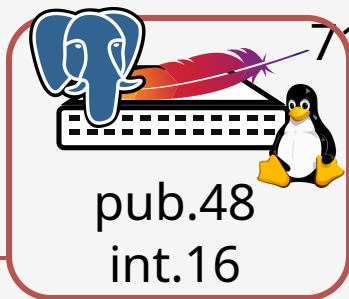


443



pub.47

7172



pub.48

int.16

nmap int.0/24

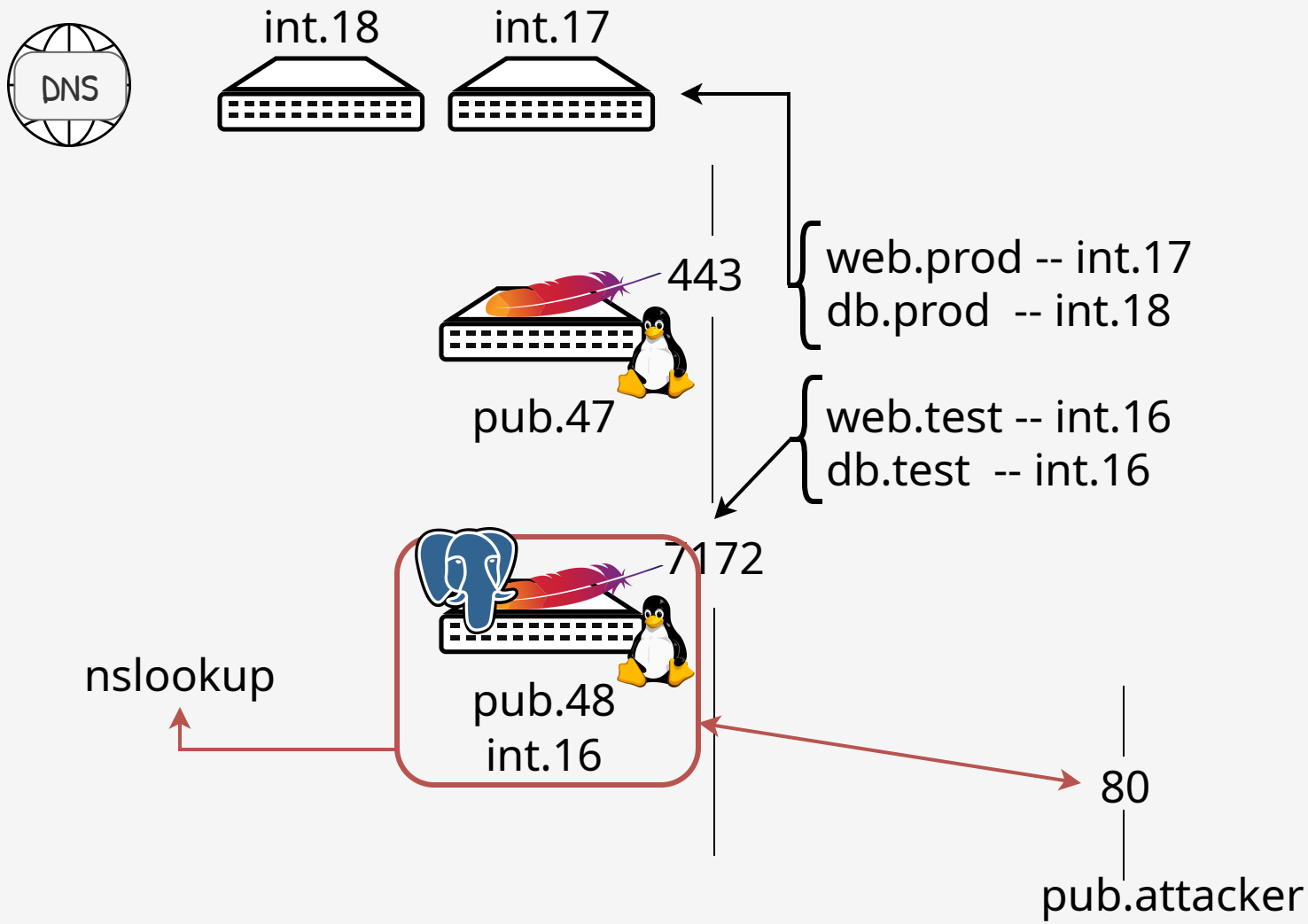


80

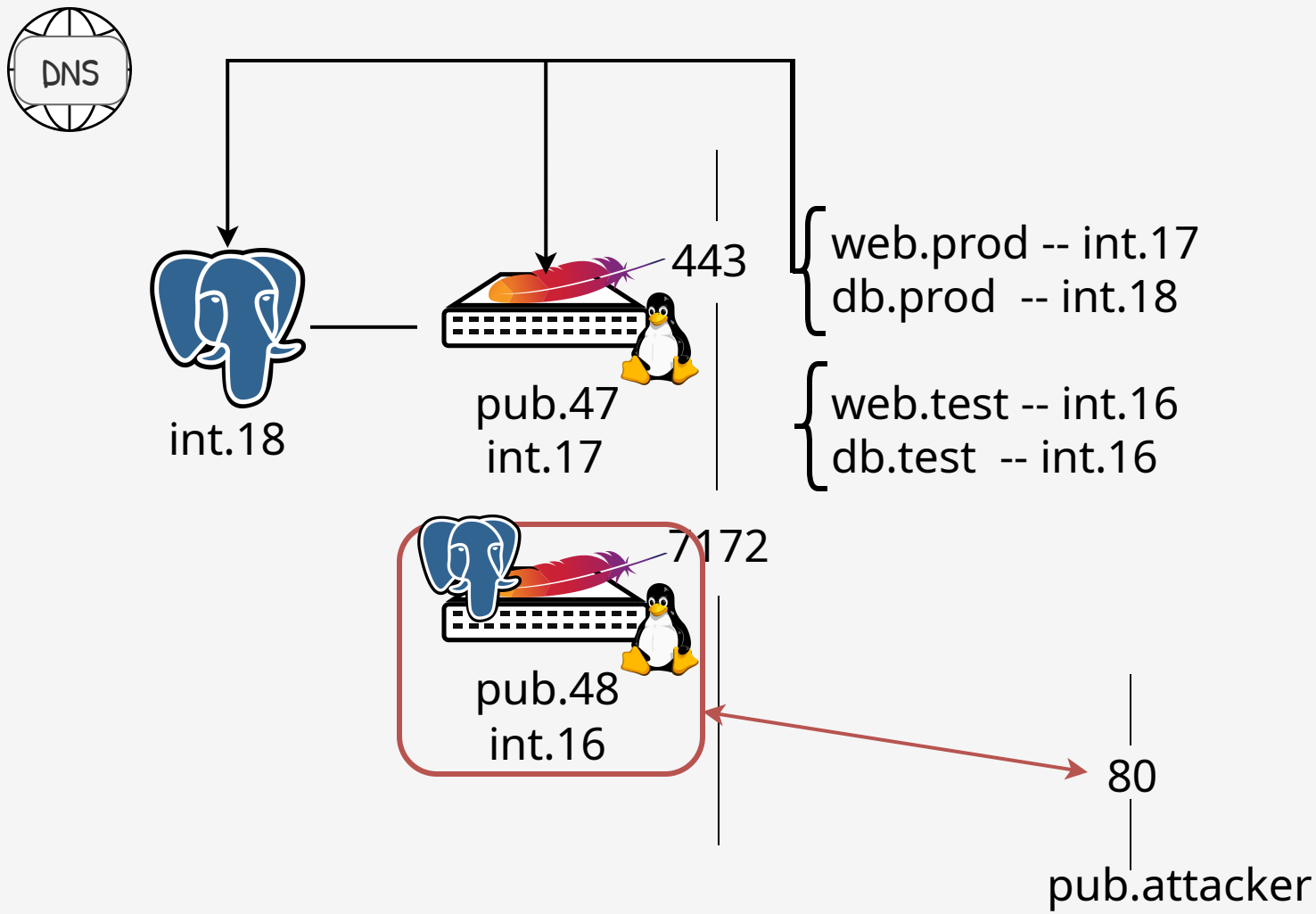


pub.attacker

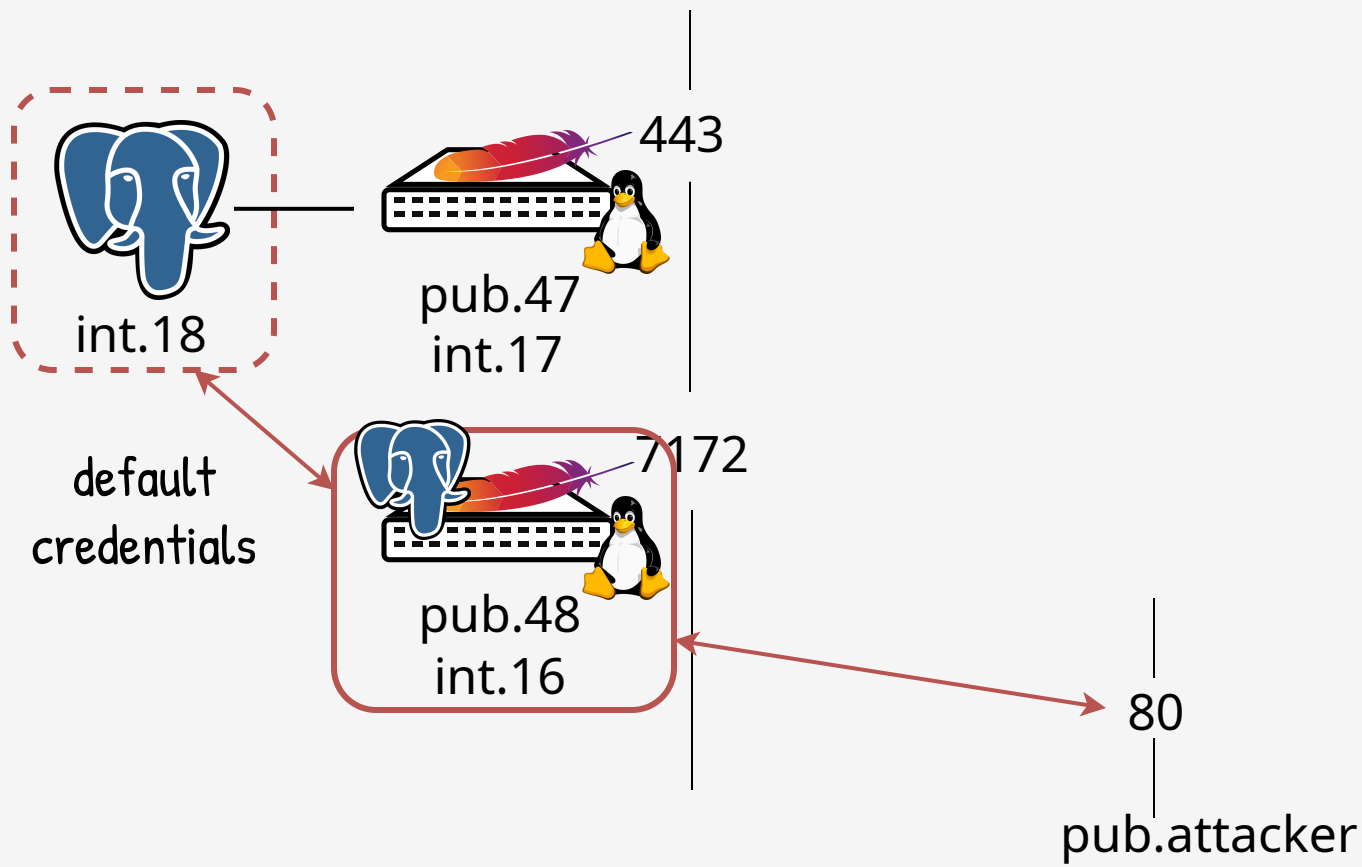
Recon



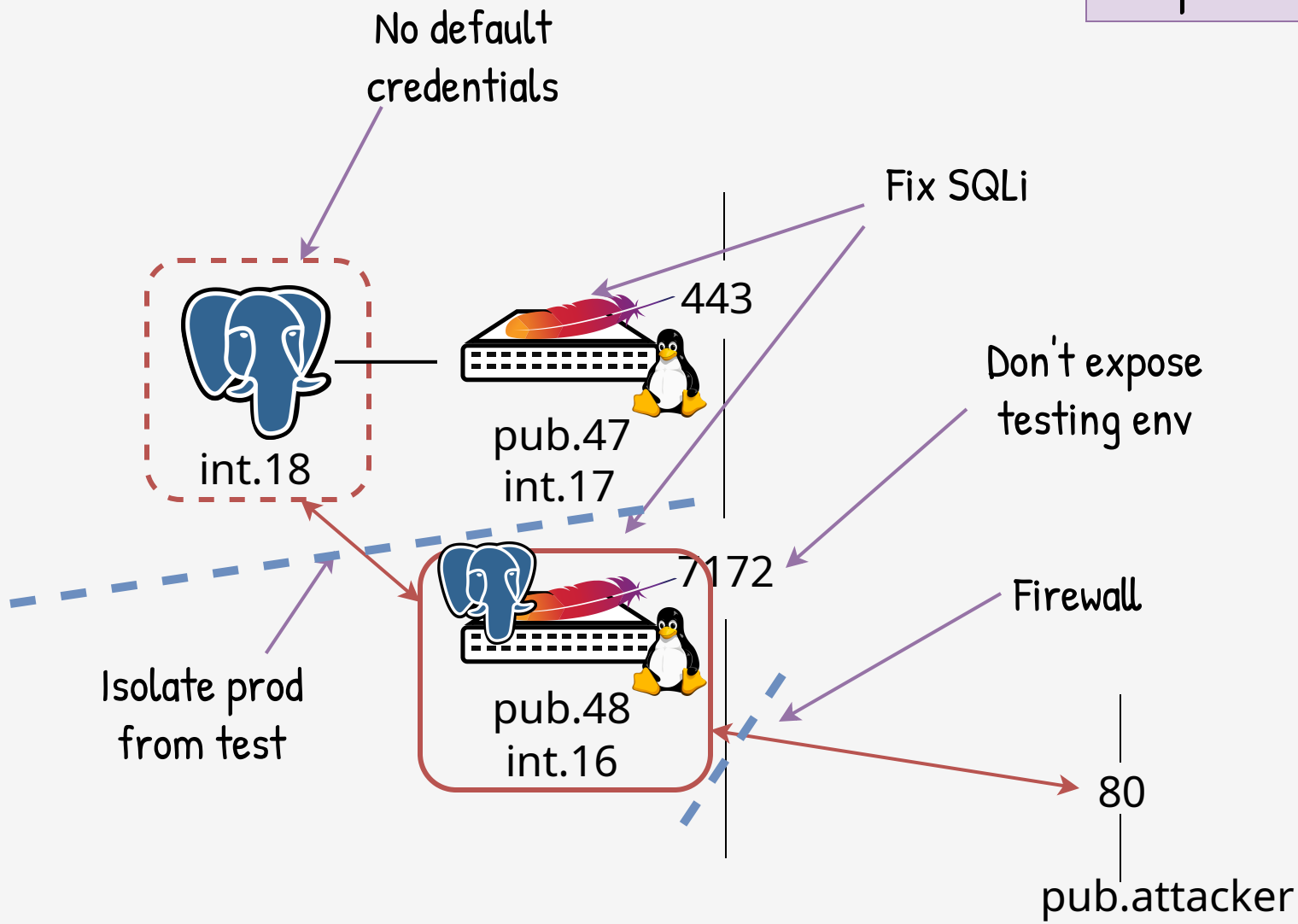
Recon



Exploit



Report



Get Info

Find Weak
Points

Exploit

repeat

Build Your
Attack Path

Profit

